

Cybersecurity Daily Newsletter

Vol. 004 | 2026-08-06 09:00 WIB

Top 5 Highlights

- Shai-Hulud strikes again: CHAINDROP worm hits 400+ npm packages
- Ransom Cartel ransomware creator sentenced to 16 years in prison
- Security validation should begin where attackers begin
- Why security validation must follow the attack path
- Hackers run khunt post-exploitation toolkit from Oracle database

Threat Intelligence (10)

01. Shai-Hulud strikes again: CHAINDROP worm hits 400+ npm packages

Elastic Security Labs identified the return of Shai-Hulud. Attackers compromised the keyv maintainer and deployed CHAINDROP, a worm that uses stolen npm credentials to backdoor co-owned packages totaling over 1.3 billion monthly downloads.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.elastic.co/security-labs/shai-hulud-chaindrop-npm-supply-chain>

02. Over 250 ClickFix Domains Use Browser Fingerprinting to Hide macOS Malware Lures

A macOS ClickFix operation spanning more than 250 front-end domains now fingerprints visitors before deciding whether to show them a malware lure, a change Microsoft Threat Intelligence tracked on infrastructure it had been watching for weeks. The server-side gate hides the malicious page from crawlers and sandboxes while presenting selected Mac users with...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/over-250-clickfix-domains-use-browser.html>

03. QuickFox VPN targeted in long-standing supply chain attack delivering FDMTP backdoor

In a report by The Hacker News, researchers disclosed a long-standing supply chain attack targeting QuickFox, a VPN and network acceleration tool used by overseas Chinese users.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.scworld.com/brief/quickfox-vpn-targeted-in-long-standing-supply-chain-attack-delivering-fdmtp-backdoor>

04. From open lures to cloaked gates: How a macOS ClickFix campaign learned to hide

A macOS ClickFix campaign shifted tactics from openly serving infostealer lures to hiding them behind a browser-fingerprinting gate. The change makes malicious infrastructure harder to detect while giving defenders new hunting opportunities. The post From open lures to cloaked gates: How a macOS ClickFix campaign learned to hide appeared first on Microsoft...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.microsoft.com/en-us/security/blog/2026/08/05/macOS-clickfix-campaign-learned-hide/>

05. Google Blogger locks hundreds of blogs in malware false positive

Google has locked hundreds of Blogger websites after a false positive claimed they violated its "Malware and Similar Malicious Content" policy, with some sites deleted from the platform. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/google/google-blogger-locks-hundreds-of-blogs-in-malware-false-positive/>

06. How AI-powered phishing killed blocklists for good

AI is helping attackers create disposable phishing infrastructure and rapidly evolving toolkits that blocklists cannot track fast enough. Push Security explains why browser-level, technique-based detection offers a more durable defense than relying on domains, signatures, and other known-bad indicators. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.bleepingcomputer.com/news/security/how-ai-powered-phishing-killed-blocklists-for-good/>

07. Trojanized npm Packages Employ NullReceiver Tactic to Decode C2 IP from Blockchain

Cybersecurity researchers have flagged an evolution of the EtherHiding blockchain-based command-and-control (C2) technique that conceals the C2 server IP address inside a made-up destination address of a completely empty Ethereum transfer. The new dead drop resolver approach, observed in two trojanized npm packages "bianira-ui" and "fluid-type-ui," has been...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/trojanized-npm-packages-decode-c2-ip.html>

08. New Attack Methods Enable Malware to Hijack Passkey-Protected Accounts

Palo Alto Networks researchers have demonstrated attacks against Google's synced passkey implementation. The post [New Attack Methods Enable Malware to Hijack Passkey-Protected Accounts](#) appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/new-attack-methods-enable-malware-to-hijack-passkey-protected-accounts/>

09. One C2 kit. 30 customers. 2 governments

I was mapping the command-and-control infrastructure behind a state-linked intrusion set when the query came back and effectively ended the exercise I thought I was running. The malware resolved its C2 address by reading a smart contract on a public blockchain. Public reporting described one contract. Working from the chain rather than the sample, I found t...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoononline.com/article/4205129/one-c2-kit-30-customers-2-governments.html>

10. ChainDrop Worm Hits 400+ npm Packages with Two Billion Monthly Installs

A new npm worm has compromised packages with over two billion monthly installs

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/chaindrop-worm-400-npm-two-billion/>

Latest Vulnerabilities (10)

01. Security validation should begin where attackers begin

Modern attacks increasingly begin with the web application. Customer portals, partner platforms, APIs, external business applications, and AI-powered services have become the front door to the enterprise. The systems organizations build to create value are now the same systems attackers target for initial access. For years, security teams have invested heav...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4205779/security-validation-should-begin-where-attackers-begin.html>

02. Why security validation must follow the attack path

For years organizations have strengthened their security posture by investing in specialized tools for applications, identities, endpoints, networks, and cloud infrastructure. Those investments remain essential, but the way attackers operate has changed dramatically. Today's adversaries move laterally, chaining together weaknesses across multiple technologi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4205771/why-security-validation-must-follow-the-attack-path.html>

03. Hackers run khunt post-exploitation toolkit from Oracle database

Hackers exploited a SQL injection vulnerability to install a post-exploitation toolkit directly inside an Oracle database that was used to breach a corporate network. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hackers-run-khunt-post-exploitation-toolkit-from-oracle-database/>

04. How a \$50,000 Exploit Chain Turned Bixby Against Samsung Phones

The chain involved the exploitation of several vulnerabilities in the Samsung Members and Samsung Account applications. The post [How a \\$50,000 Exploit Chain Turned Bixby Against Samsung Phones](#) appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.securityweek.com/how-a-50000-exploit-chain-turned-bixby-against-samsung-phones/>

05. Pre-auth RCE in enterprise Java hits Bonita and OFBiz servers

An attacker sends a single web request to a Bonita server and lands inside an internal API that assumed nobody could reach it. The request arrives unauthenticated. From there the attacker runs code on the host. Bonita BPM handles loan approvals, insurance claims, and employee onboarding for banks, insurers, and government agencies, and its internal surface...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/08/05/pre-auth-rce-java-bonita-ofbiz-cve-2026-31986/>

06. Flaws in Google APK for Python Unlock Agent-to-Agent Attack

Google has fixed the issues, which exploited a trust boundary between two AI agents with different privilege levels to trigger automation that could compromise the supply chain.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/vulnerabilities-threats/flaws-google-apk-python-agent-to-agent-attack>

07. COLDCARD security audit phishing attack installs remote access tool

A phishing campaign is exploiting fears surrounding the recently disclosed COLDCARD wallet vulnerability and suspected \$88.6 million Bitcoin theft to trick users into installing ScreenConnect remote access software. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/coldcard-security-audit-phishing-attack-installs-remote-access-tool/>

08. IBM's agentic AI platform is under active attack - patch now

A critical Langflow flaw allowing RCE on default deployments is being exploited, says the CISA

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/08/05/ibms-agentic-ai-platform-is-under-active-attack-patch-now/5283535>

09. CISA warns of hackers exploiting Langflow, N-central, Apache Tomcat flaws

The U.S. Cybersecurity and Infrastructure Security Agency is giving federal agencies three days to mitigate vulnerabilities in IBM Langflow, N-central, and Apache Tomcat, all actively exploited. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisa-warns-of-hackers-exploiting-langflow-n-central-apache-tomcat-flaws/>

10. Paperclip AI Flaws Let Attackers Run Host Commands via Malicious Agent Imports

Two security flaws in Paperclip could let attackers execute commands on a network server or a developer's computer. Paperclip is an open-source control plane for teams of artificial intelligence (AI) agents, and both paths rely on importing a malicious agent and starting it. A third flaw could expose sensitive data and control-plane details through applicat...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/08/paperclip-ai-flaws-let-attackers-run.html>

Data Breach & Cybercrime (10)

01. Ransom Cartel ransomware creator sentenced to 16 years in prison

Maksim Silnikau, the creator and administrator of the Ransom Cartel ransomware operation, was sentenced to 16 years in prison for his role in ransomware attacks against at least 18 companies worldwide. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/ransom-cartel-ransomware-creator-sentenced-to-16-years-in-prison/>

02. OpenAI Disrupts Poipet Scam Network Using ChatGPT Across Multiple Fraud Schemes

OpenAI said it disrupted a Cambodia-based scam operation that used its generative artificial intelligence (AI) chatbot ChatGPT to facilitate a wide range of investment, romance, gambling, and law enforcement impersonation schemes. To that end, it banned a coordinated network of ChatGPT accounts likely originating from Southeast Asia and operating from the c...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/08/openai-disrupts-poipet-scam-network.html>

03. AI Sends Global Crime Syndicates Into Fraud Nirvana

Organized crime is convincingly scamming at scale, making billions thanks to AI-enabled voice cloning, deepfake real-time video overlays, LLM-driven persona management, and automated translation.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/threat-intelligence/ai-global-crime-syndicates-fraud-nirvana>

04. Don't Revoke That Token Yet: Inside the keyv/cacheable npm Worm, (Wed, Aug 5th)

When you learn that a compromised package executed on one of your build hosts, muscle memory takes over: revoke the npm token, rotate the GitHub PAT, cycle the cloud keys. That reflex has been correct in almost every supply-chain incident I have worked. In the keyv/cacheable compromise that has been unfolding since yesterday, it is the one thing you should...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://isc.sans.edu/diary/rss/33218>

05. Cybercrime victims lose an average of \$9,468, with global toll exceeding \$1.24 trillion

New figures reveal that cybercrime victims are losing an average of \$9,468 per incident, highlighting the escalating global scale of this problem.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/cybercrime-victims-lose-an-average-of-9468-with-global-toll-exceeding-1-24-trillion>

06. CAF Bank online service restored after attempted fraud and login removal

CAF Bank restored its online banking service after a prolonged outage lasting more than 10 days, which the bank attributed to attempted fraud and a subsequent attack aimed at removing user logins.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/caf-bank-online-service-restored-after-attempted-fraud-and-login-removal>

07. Poison Claude Sells Discounted Claude Access While Its Operator Sees Every Customer Prompt

Cybersecurity researchers have discovered more than half-a-dozen services advertisements for illegal access to artificial intelligence (AI) models on underground cybercrime forums and messaging platforms. One such service, Poison Claude, claims to offer access to Anthropic's large language models (LLMs), including Opus 4.8, Opus 4.7, Opus 4.6, and Sonnet 4....

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/08/poison-claude-sells-discounted-claude.html>

08. London cops handed victim's new address and number to her stalker, watchdog says

Met ordered to improve safeguards after two preventable data breaches

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/08/05/london-cops-handed-victims-new-address-and-number-to-her-stalker-watchdog-says/5283382>

09. INTERPOL flags AI as the new engine of African cybercrime

Africa's growing digital economy is exposing governments, businesses and internet users to a rising wave of cybercrime. The continent recorded more than 1.1 billion mobile subscriptions and over \$1.1 trillion in digital transactions in 2025, while more than 570 million people relied on the internet for banking, government services, healthcare and education....

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/08/05/interpol-africa-cybercrime-trends/>

10. 311,000 Impacted by Brown Health Medical Group-MA Data Breach

Hackers stole personal information, medical records, and financial information from the organization's server. The post 311,000 Impacted by Brown Health Medical Group-MA Data Breach appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/311000-impacted-by-brown-health-medical-group-ma-data-breach/>